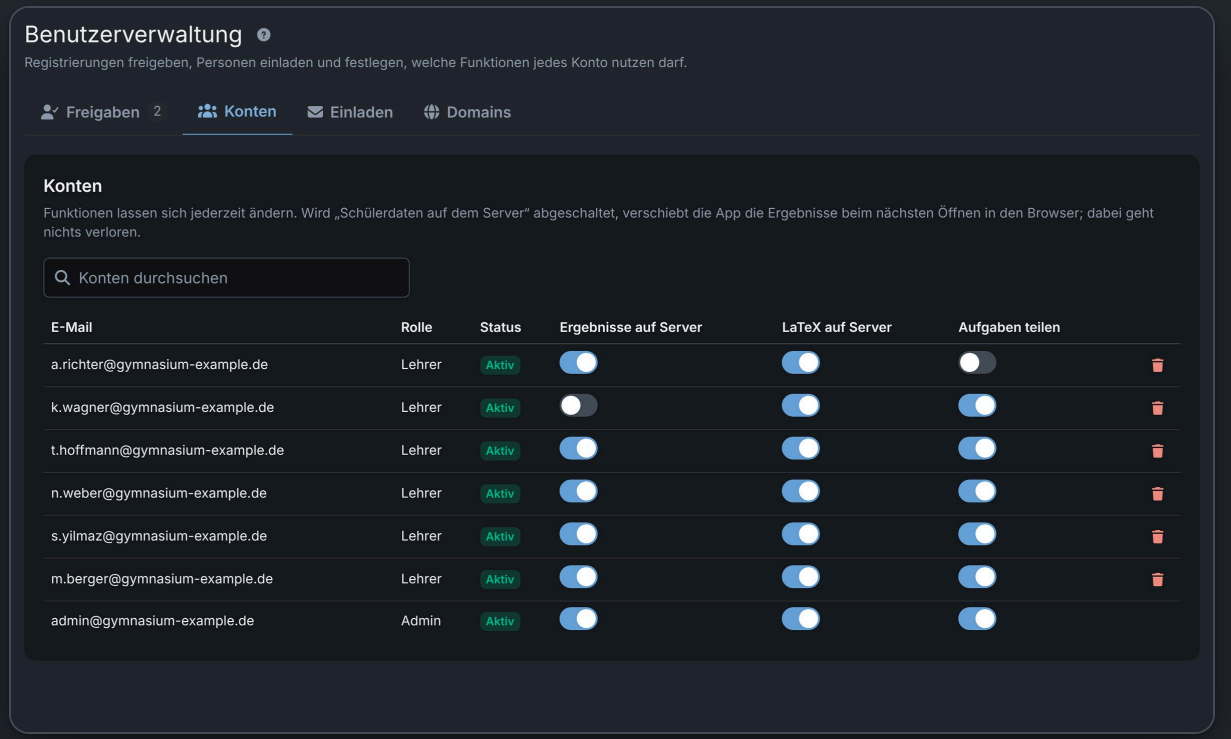
FÜR SCHULLEITUNG, DATENSCHUTZ UND IT

Was Examance mit Prüfungsdaten macht – und was nicht.

Ein Überblick über Datenflüsse, Verschlüsselung, Rollen und die Punkte, die eine Schule vor dem Einsatz selbst entscheiden muss.



- Benutzerverwaltung: Funktionen je Konto ein- und ausschalten

WORUM ES GEHT

Ein Werkzeug für schriftliche Prüfungen auf Papier

Lehrkräfte stellen Klausuren aus einer Aufgabenbibliothek zusammen, lassen sie wie gewohnt schreiben, scannen den Stapel und korrigieren am Bildschirm – ohne dabei die Namen zu sehen.

1
Aufgaben
Bibliothek je Lehrkraft, optional in der Fachschaft geteilt.

2
Klausur
Druckfertiges PDF mit Notenschlüssel und Lösung.

3
Papier
Schülerinnen und Schüler schreiben wie bisher.

4
Scan
QR-Code mit Pseudonym ordnet die Bögen zu.

5
Korrektur
Anonym, danach Noten und Auswertung.

Web-Anwendung
Keine Installation auf Schulrechnern; jede Lehrkraft hat ein eigenes Serverkonto.

Offener Quellcode
MIT-Lizenz. Die Schule kann den Code prüfen lassen und selbst betreiben.

Beta
Version 0.2. Für einen begrenzten, begleiteten Einsatz gedacht, nicht für den flächigen Betrieb.

DATENFLUSS

Verschlüsselt wird im Browser – vor dem Speichern

Browser der Lehrkraft
Der Schlüssel entsteht hier aus der Anmeldung und verlässt das Gerät nicht. Scans werden hier gelesen und verschlüsselt.

→

Übertragung
Nur Chiffrat für Schülerdaten, über TLS.

→

Server
Speichert Chiffrat, Kontodaten und die Aufgabenbibliothek. Kann Schülerdaten nicht entschlüsseln.

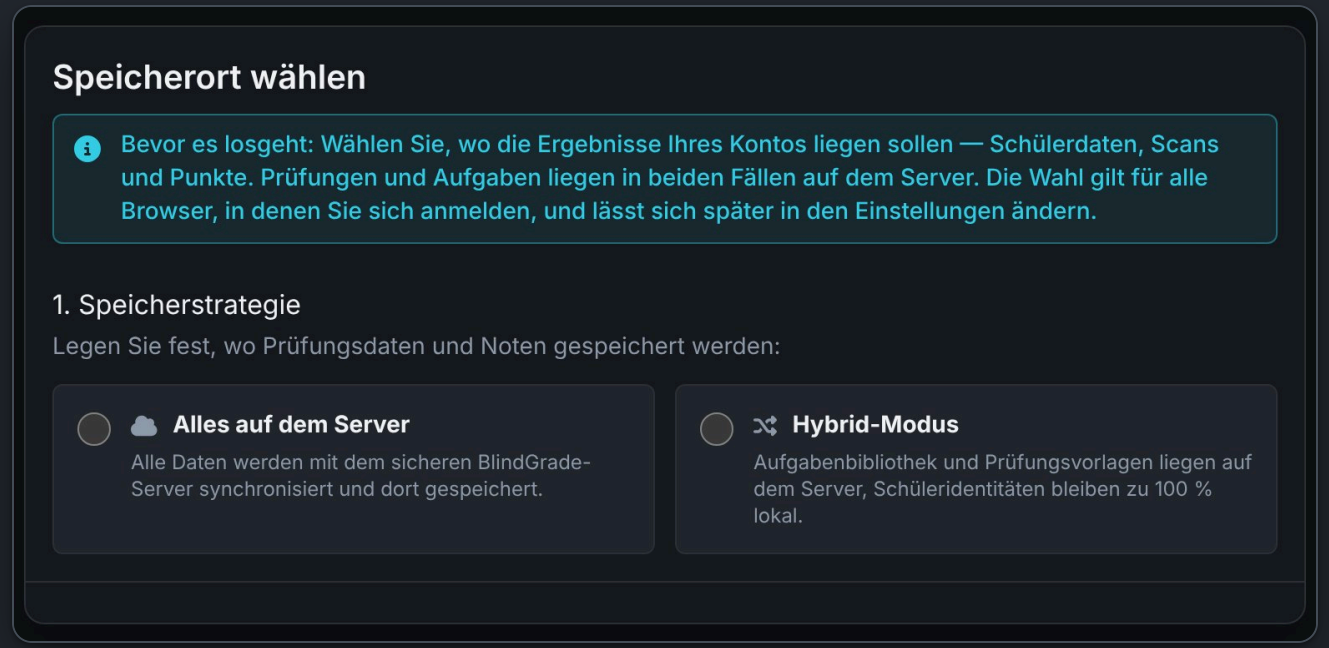
Daten	Wo	Für den Server lesbar?
Namen, Schülernummern, Scans, Anmerkungen, Einzelpunkte	Browser; im Server-Modus zusätzlich auf dem Server	Nein – AES-256-GCM, Schlüssel nur im Browser
Gesamtpunktzahl je Abgabe (pseudonym)	Server	Ja, ohne Namen
Klausurdaten: Titel, Klasse, Fach, Datum, Nachname der Lehrkraft	Server	Ja
Aufgaben- und Klausurtexte (LaTeX)	Server	Ja
Konto: E-Mail, Rolle, Passwort-Hash, Freischaltungen	Server	Ja (Passwort nur als Argon2id-Hash)

SPEICHERORT

Zwei Modi, pro Konto festgelegt

	Hybrid	Server
Aufgaben, Klausuren	Server	Server
Schülerdaten, Scans, Punkte	nur im Browser	Server, verschlüsselt
Mehrere Geräte	nein	ja
Sicherung	verschl. Archiv	serverseitig

Hinweis Hybrid: Die Daten liegen dann auf dem Gerät der Lehrkraft. Landesrecht kann die Verarbeitung auf privaten Endgeräten einschränken (in Bayern z. B. ausdrücklich geregelt).



- Bei der ersten Anmeldung muss der Modus gewählt werden

Die Administration legt pro Konto fest, ob der Server-Modus erlaubt ist. Wird er entzogen, verschiebt die App die Ergebnisse beim nächsten Öffnen in den Browser; ein Wechsel wird geprüft, bevor die alte Kopie gelöscht wird.

ROLLEN

Was die Administration kann – und was nicht

Kann

- Registrierungen freigeben oder ablehnen, Personen einladen
- Domains festlegen, deren Adressen automatisch freigeschaltet werden
- Pro Konto: Ergebnisse auf dem Server, LaTeX auf dem Server, Aufgaben teilen
- Konten löschen; Rollen werden auf dem Server per Kommandozeile geändert

Kann nicht

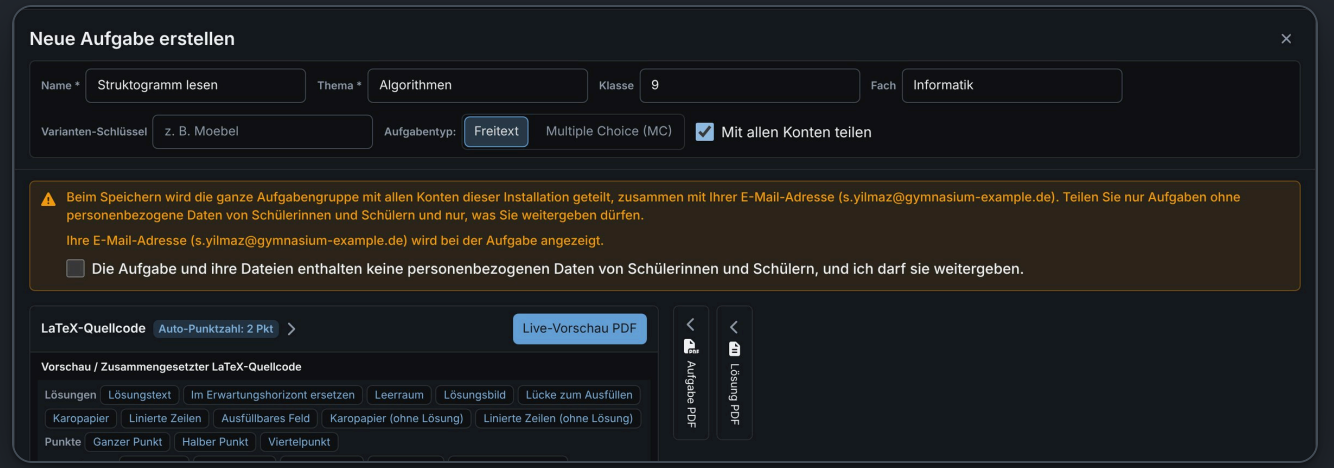
- Klausuren, Aufgaben oder Ergebnisse von Lehrkräften öffnen – Admin-Konten haben gar keinen Zugriff auf Unterrichtsdaten
- Verschlüsselte Schülerdaten lesen, auch nicht direkt in der Datenbank
- Nach einem Passwort-Reset die Daten einer Lehrkraft wiederherstellen; dafür gibt es nur ihren persönlichen Wiederherstellungscode

Das ist Absicht: Wer den Server betreibt, soll Prüfungsdaten nicht einsehen können – auch nicht bei einem Einbruch in den Server.

AUFGABEN TEILEN

Teilen ist steuerbar – und betrifft nie Schülerdaten

- Lehrkräfte können Aufgaben mit allen Konten der Instanz teilen, Kopien übernehmen und dem Original Verbesserungen vorschlagen.
- Die Administration schaltet die Funktion **pro Konto** ein oder aus.
- Vor dem ersten Teilen bestätigt die Lehrkraft ausdrücklich: keine personenbezogenen Daten von Schülerinnen und Schülern, und sie darf die Aufgabe weitergeben.
- Bei geteilten Aufgaben und Vorschlägen ist die E-Mail-Adresse der Lehrkraft sichtbar; darauf weist die App vorher hin.
- Geteilt werden nur Aufgabentexte und ihre Dateien – keine Klausuren, Scans oder Ergebnisse.

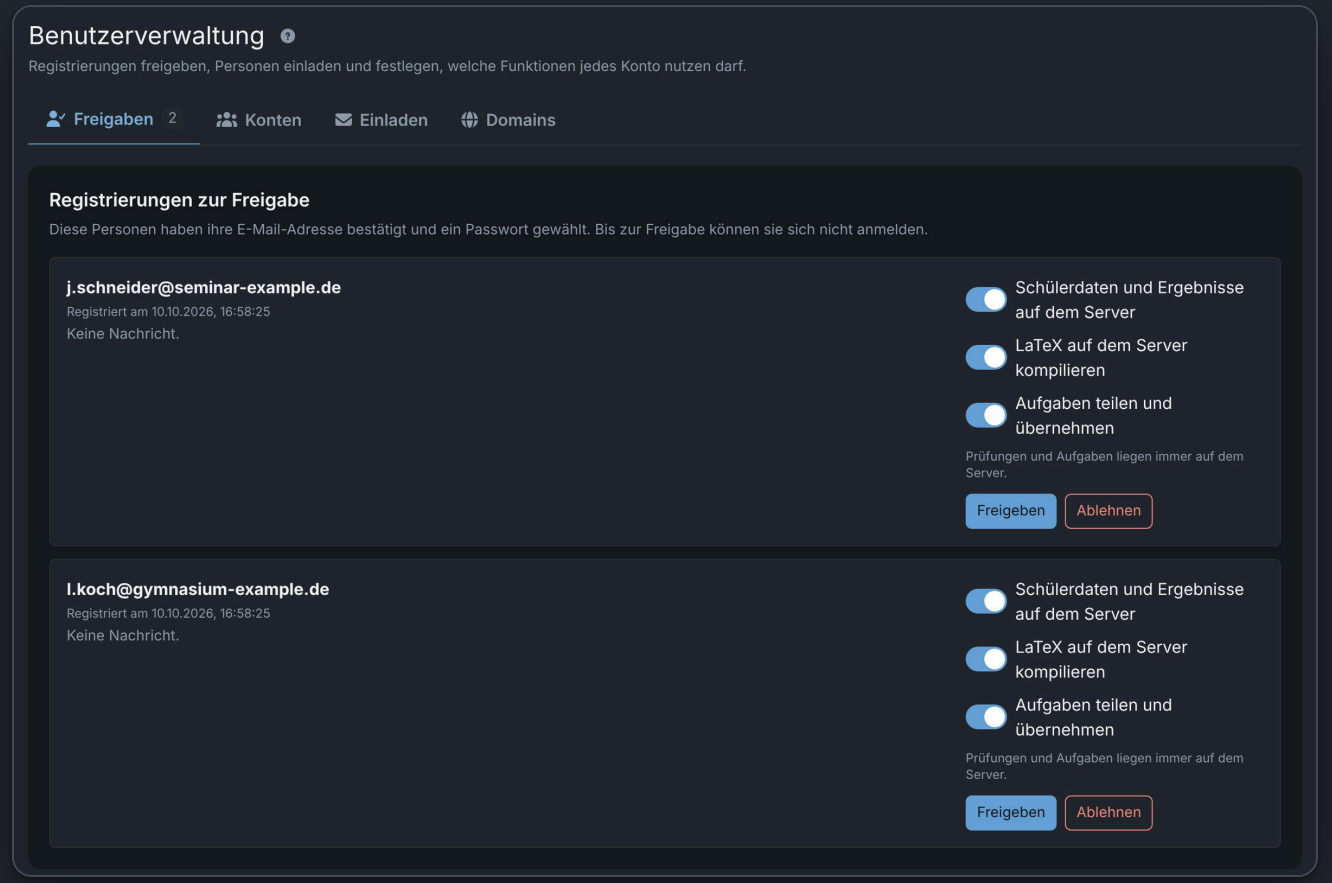


Hinweis und Pflichtbestätigung beim Teilen einer Aufgabe

KONTEN

Wer ein Konto bekommt, entscheidet die Schule

- **Einladung** durch die Administration, oder
- **Registrierung**: E-Mail bestätigen, Passwort wählen, dann Freigabe durch die Administration.
- Adressen von hinterlegten Schul-Domains werden nach der E-Mail-Bestätigung automatisch freigeschaltet.
- Unbestätigte und nicht freigegebene Anträge werden nach einer Frist automatisch gelöscht.

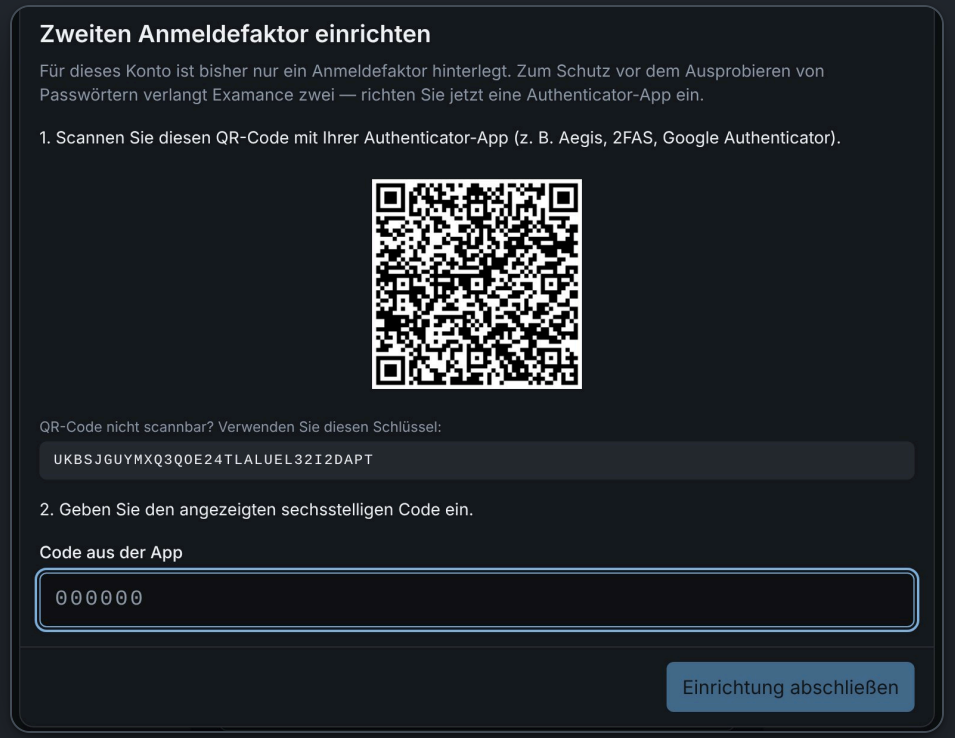


- Freigaben: zwei Registrierungen warten, Funktionen vorab wählbar

ANMELDUNG

Ein Passwort allein reicht nicht

- Zwei von drei Faktoren: Passwort, Authenticator-App, Passkey. Ein Passkey mit Geräte-PIN oder Biometrie genügt allein.
- Ohne zweiten Faktor erreicht ein Konto nichts außer der Einrichtung.
- Sperre nach Fehlversuchen pro Konto, zeitlich begrenzt.
- Sitzungen laufen nach Inaktivität ab; ein gesperrter Tab enthält keine lesbaren Daten.
- Protokoll sicherheitsrelevanter Aktionen, IP-Adressen nur als Hash.



Erste Anmeldung: der zweite Faktor ist Pflicht

BETRIEB

Drei Betriebsmodelle, drei Verantwortungslagen

Modell	Verantwortlich für Schülerdaten	Was es braucht
A · Schule betreibt selbst Backend als Docker-Container, Frontend statisch	Die Schule	Kein Auftragsverarbeitungsvertrag; Verzeichnis, DSFA und Information der Betroffenen durch die Schule
B · Dienstleister betreibt für Schulen	Die Schule	Vertrag zur Auftragsverarbeitung (Vorlage liegt bei), Unterauftragnehmer offenlegen
C · Private Instanz für Lehrkräfte so läuft die aktuelle Beta-Instanz	Lehrkraft bzw. ihre Schule	Klärung mit der Schule, bevor echte Schülerdaten verarbeitet werden

Wird das Frontend über einen CDN-Anbieter mit Sitz in den USA ausgeliefert, ist das eine Drittlandübermittlung von Zugriffsdaten. Beim Selbstbetrieb in der EU entfällt sie.

UNTERLAGEN

Was bereits dokumentiert ist

Datenfluss & Sicherheit

Schlüsselableitung, Verschlüsselung, Sitzungen, Anmeldefaktoren, bekannte Kompromisse.

DSGVO-Prüfung

Technische Bewertung gegen DSGVO, BDSG und bayerisches Schulrecht, mit Befunden und Stand.

DSFA-Vorlage

Datenschutz-Folgenabschätzung nach Art. 35, vorbereitet zum Ausfüllen.

Verzeichnis (Art. 30)

Vorlage für das Verzeichnis von Verarbeitungstätigkeiten.

AV-Vertrag

Vorlage für die Auftragsverarbeitung (Modell B).

Vorfallsplan

Checkliste für den Fall einer Datenpanne, mit Meldewegen.

Diese Unterlagen sind **Arbeitsvorlagen aus der Entwicklung**. Sie ersetzen weder die Prüfung durch die oder den Datenschutzbeauftragten noch eine Rechtsberatung.

VOR EINEM EINSATZ

Was die Schule entscheiden muss

- Rechtsgrundlage bestätigen (in Bayern Art. 85 BayEUG mit BaySchO)
- Aufbewahrungsfrist für Prüfungsarbeiten festlegen
- Betriebsmodell wählen, ggf. AV-Vertrag schließen
- DSFA abschließen und das Verzeichnis ergänzen

- Regel für private Endgeräte, besonders für den Hybrid-Modus
- Welche Funktionen freigeschaltet werden (Server-Ergebnisse, Teilen)
- Ansprechperson und Supportweg für Lehrkräfte
- Information der Schülerinnen, Schüler und Eltern

Für Auskunft und Löschung nach Art. 15 und 17 DSGVO gibt es in der App eine eigene Ansicht je Schülerin und Schüler. Ein täglicher Aufbewahrungslauf löscht abgelaufene Daten auf dem Server; die Fristen sind konfigurierbar und stehen in der Datenschutzerklärung der Instanz.

VORSCHLAG

Erst ein begrenzter Pilot

1

Rahmen

Eine Fachschaft, ein Halbjahr, wenige freiwillige Lehrkräfte.

2

Probelauf

Zuerst mit erfundenen Daten, dann eine echte Kurzarbeit.

3

Begleitung

Datenschutzprüfung parallel; Rückfragen an einen festen Kontakt.

4

Bilanz

Zeitaufwand, Fehler bei Scan und Erkennung, Akzeptanz, offene Rechtsfragen.

Ausstieg jederzeit

Ergebnisse lassen sich als Tabelle und als verschlüsseltes Archiv exportieren; Lehrkräfte können ihr Konto selbst löschen.

Ansehen statt glauben

Der komplette Ablauf lässt sich mit einer Probeklausur und erfundenen Daten vorführen, einschließlich Benutzerverwaltung.